



INSTITUTO TECNOLÓGICO Y DE ESTUDIOS SUPERIORES DE MONTERREY

Escuela de Ingeniería y Ciencias
Ingeniería en Ciencia de Datos y Matemáticas

GESTOR DE IDENTIDADES V1.0

Manual de Usuario

Socio Formador: Casa Monarca

Equipo de trabajo: 1 | Grupo: 603

Integrantes:

Miranda Cornejo Ahuja — A01571668
Natalia Cervantes González — A00838465
Hugo Jaime Valdés — A01384039
Jorge Alfonso Andujo Valdéz — A01563535
Ana Sofía Ibarra Ponce — A01285836

Profesores:

Raúl Gómez, Anas Waji y Alberto F. Martínez

Monterrey, Nuevo León
5 de junio de 2026

Índice de Contenidos

Introducción	3
¿Qué es la aplicación?	3
¿Para qué sirve?	3
¿A quién va dirigida?	3
Requerimientos del Sistema	4
Hardware mínimo	4
Software necesario	4
Para usuario final (solo acceso vía navegador):	4
Para instalación local (administradores técnicos):	4
Versiones compatibles	5
Instalación	6
Consideraciones previas	6
Instalación del Backend	6
Instalación del Frontend	6
Variables de entorno principales	7
Puertos y URLs del sistema	7
Inicio de la Aplicación	9
Cómo acceder	9
Inicio de sesión — Doble factor obligatorio	9
Paso 1 — Ingresar credenciales	9
Paso 2 — Verificación con código TOTP	9
Configuración inicial — Enrolamiento TOTP	10
Activación de cuenta nueva	10
Guía de Uso	12
Panel de administración (Dashboard)	12
Registrar un nuevo colaborador	12
Paso a paso:	12
Resultado esperado:	13
Registrar una persona migrante	13
Paso a paso:	13
Resultado esperado:	14
Consultar y gestionar registros de migrantes	14
Buscar un registro:	14
Workflow de un registro:	15
Aprobar un registro (Coordinador / Administrador):	15
Módulo ARCO — Derechos de privacidad	15
Tipos de solicitud:	16
Crear una solicitud ARCO:	16
Atender una solicitud ARCO:	16
Solicitudes de eliminación	17
Solicitar la eliminación de un registro:	17
Aprobar o rechazar (Administrador):	18
Firma digital — Configuración del certificado	18
Generar el certificado:	18
Verificar una firma existente:	19
Consultar la bitácora de auditoría	19
Paso a paso:	19
Gestionar el estado de un colaborador	20
Solución de Problemas	21
Errores comunes y soluciones	21
¿Qué hacer si algo falla inesperadamente?	21
Preguntas Frecuentes (FAQ)	22
Glosario	23
Repositorio del proyecto	24

Introducción

¿Qué es la aplicación?

El Gestor de Identidades V1.0 (Casa Monarca — Identity Access Manager) es una aplicación web desarrollada para gestionar de forma segura las identidades digitales de los colaboradores de Casa Monarca, organización sin fines de lucro que atiende a población migrante vulnerable. El sistema centraliza el ciclo de vida de cada usuario —alta, activación, autenticación, revocación y auditoría— usando criptografía de clave pública (RSA-2048 y ECDSA P-256), autenticación de doble factor y control de acceso basado en roles (RBAC).

¿Para qué sirve?

La aplicación permite a la organización:

- Registrar colaboradores con identidades digitales respaldadas por certificados internos.
- Controlar quién accede a qué información según su rol y nivel de responsabilidad.
- Registrar personas migrantes con integridad criptográfica (hash SHA-256) y cifrado de campos sensibles.
- Firmar documentos digitalmente con certificados ECDSA P-256 (flujo similar al SAT).
- Mantener una bitácora inmutable de todas las acciones críticas para garantizar trazabilidad.

¿A quién va dirigida?

Este manual está dirigido al personal de Casa Monarca sin necesidad de conocimientos técnicos avanzados. La siguiente tabla resume los cuatro niveles de usuario:

Nivel	Rol	Permisos principales
1	Administrador del Sistema	Acceso completo: gestión de usuarios, bitácora, plantillas y eliminación de registros.
2	Coordinador de Área	Crear, leer y editar registros. Sin eliminar ni gestionar usuarios.
3	Personal Operativo	Crear y leer registros. Sin editar ni eliminar.
4	Personal Externo (becarios, voluntarios)	Solo crear registros. Sin lectura de registros internos.

Tabla 1. Niveles de acceso y permisos principales del sistema.

Requerimientos del Sistema

Hardware mínimo

Componente	Mínimo recomendado
Procesador	Intel Core i3 / AMD Ryzen 3 (o equivalente) — 2.0 GHz
Memoria RAM	4 GB (8 GB recomendado para ejecutar backend + frontend localmente)
Almacenamiento	2 GB libres en disco (adicionales para base de datos en producción)
Conexión de red	Requerida para acceso al sistema desplegado; 10 Mbps o superior

Tabla 2. Requisitos mínimos de hardware.

Software necesario

Para usuario final (solo acceso vía navegador):

Software	Versión mínima	Notas
Google Chrome	110+	Recomendado (compatibilidad total con Web Crypto API)
Mozilla Firefox	115+	Compatible
Microsoft Edge	110+	Compatible
Safari	16+	Compatible con limitaciones menores

Tabla 3. Navegadores web compatibles para usuario final.

Para instalación local (administradores técnicos):

Software	Versión	Propósito
Python	3.9 o superior	Ejecución del backend FastAPI
Node.js	18 o superior	Build del frontend React/Vite
MySQL	8.0 (producción)	Base de datos en entorno productivo
SQLite	Incluido en Python	Base de datos en entorno de desarrollo

Tabla 4. Software requerido para instalación local por administradores técnicos.

Versiones compatibles

Librería / Framework	Versión
FastAPI	0.110.0
React	18.2.0
SQLAlchemy	2.0.29
cryptography (Python)	≥ 42.0.0
Vite	5.2.11
pyotp	2.9.0

Tabla 5. Versiones de librerías y frameworks utilizados en el sistema.

Instalación

Consideraciones previas

Antes de instalar el sistema, tenga en cuenta los siguientes puntos:

- El sistema consta de dos partes independientes: un backend (Python/FastAPI) y un frontend (React/Vite). Ambos deben ejecutarse simultáneamente.
- Para entorno de desarrollo se utiliza SQLite, que no requiere instalación adicional. Para producción se requiere MySQL 8.0.
- El proyecto no incluye Docker. La instalación se realiza directamente sobre el sistema operativo.

Instalación del Backend

Ejecute los siguientes pasos en orden desde la terminal:

1. Ubíquese en la carpeta del backend:

```
cd backend
```

2. Cree y active el entorno virtual de Python:

```
python -m venv .env
.venv\Scripts\activate      # Windows
source .venv/bin/activate   # Linux / macOS
```

3. Instale las dependencias:

```
pip install -r requirements.txt
```

4. Configure las variables de entorno:

```
copy .env.example .env      # Windows
cp .env.example .env         # Linux / macOS
```

5. Edite el archivo .env con los parámetros de su entorno (ver sección de Variables de entorno principales).

6. Aplique las migraciones de base de datos:

```
alembic upgrade head
```

7. Ejecute el seed inicial para crear roles, áreas y usuario administrador:

```
python -m scripts.seed_initial_data
```

8. Inicie el servidor:

```
uvicorn app.main:app --reload --host 0.0.0.0 --port 8000
```

Verificación: Abra su navegador y acceda a <http://localhost:8000/health>. Debe recibir la respuesta {"status": "ok"}.

Instalación del Frontend

1. Ubíquese en la carpeta del frontend:

```
cd frontend
```

2. Instale las dependencias de Node.js:

```
npm install
```

3. Configure la URL del backend:

```
copy .env.example .env      # Windows
cp .env.example .env        # Linux / macOS
```

Edite el archivo `.env` y asegúrese de que contenga:

```
VITE_API_URL=http://localhost:8000/api/v1
```

4. Inicie el servidor de desarrollo:

```
npm run dev
```

Verificación: Abra su navegador y acceda a `http://localhost:5173`. Debe visualizar la pantalla de inicio de sesión del sistema.

Variables de entorno principales

Variable	Descripción	Ejemplo / Valor por defecto
SECRET_KEY	Clave secreta para firmar JWT. Debe ser aleatoria en producción.	<code>python -c "import secrets; print(secrets.token_hex(32))"</code>
SQLITE_PATH	Ruta de la base de datos SQLite (solo desarrollo).	<code>./app.db</code>
DATABASE_URL	URL de conexión MySQL (producción).	<code>mysql+pymysql://user:pass@host:3306/db</code>
SMTP_HOST	Servidor de correo saliente. Vacío = modo demo activo.	<code>smtp.gmail.com</code>
FIELD_ENCRYPTION_KEY	Clave Fernet para cifrar campos sensibles.	<code>Fernet.generate_key().decode()</code>
ADMIN_EMAIL	Correo del administrador creado en el seed.	<code>admin@demo.org</code>
ADMIN_PASSWORD	Contraseña del administrador creado en el seed.	<code>Admin123!</code>
CORS_ORIGINS	Orígenes permitidos para el frontend.	<code>http://localhost:5173</code>

Tabla 6. Variables de entorno principales y sus valores por defecto.

Puertos y URLs del sistema

Servicio	Puerto	URL local
Frontend (desarrollo)	5173	<code>http://localhost:5173</code>
Backend API	8000	<code>http://localhost:8000</code>
Documentación Swagger	8000	<code>http://localhost:8000/docs</code>
Documentación ReDoc	8000	<code>http://localhost:8000/redoc</code>

Health check	8000	http://localhost:8000/health
--------------	------	------------------------------

Tabla 7. Puertos y URLs del sistema en entorno local de desarrollo.

Inicio de la Aplicación

Cómo acceder

Una vez que backend y frontend estén en ejecución, abra su navegador web preferido (Chrome o Firefox recomendado) e ingrese la dirección del sistema. En entorno local es `http://localhost:5173`. Si el sistema está desplegado en un servidor, utilice la URL que le haya proporcionado el administrador técnico.

Inicio de sesión — Doble factor obligatorio

El sistema requiere dos pasos para autenticarse. Este mecanismo de doble factor (2FA) protege la cuenta incluso si alguien conoce su contraseña.

Paso 1 — Ingresar credenciales

1. En la pantalla de inicio, ingrese su correo electrónico y contraseña.
2. Haga clic en el botón **Iniciar sesión**.
3. El sistema validará sus credenciales y, si son correctas, le solicitará el segundo factor.

The image shows a login form for 'CASA MONARCA'. At the top is the logo, which consists of a stylized orange and red shape above the text 'CASA MONARCA' and a smaller tagline 'INSTITUTO TECNOLÓGICO Y DE ESTUDIOS SUPERIORES DE MONTERREY, S.C.'. Below the logo are two input fields: 'Correo electrónico' with the placeholder 'usuario@ejemplo.org' and 'Contraseña' with a masked password 'xxxxxxx'. At the bottom of the form is a red button with the text 'Iniciar sesión'.

Figure 2: Formulario de inicio de sesión con campos de correo y contraseña.

Paso 2 — Verificación con código TOTP

1. Abra su aplicación autenticadora (Google Authenticator, Microsoft Authenticator o similar).
2. Localice la cuenta "Casa Monarca" y obtenga el código de 6 dígitos vigente.
3. Ingrese el código en el campo de verificación y haga clic en **Verificar código**.
4. Los códigos TOTP cambian cada 30 segundos. Si el código no funciona, espere al siguiente.



Figure 3: Pantalla de verificación del segundo factor (TOTP) con campo de 6 dígitos.

Configuración inicial — Enrolamiento TOTP

Si es la primera vez que accede, deberá enrollar su dispositivo como segundo factor. El sistema le presentará un código QR:

1. Abra su aplicación autenticadora en el teléfono.
2. Seleccione la opción **Agregar cuenta** o **Escanear código QR**.
3. Escanee el código QR que muestra el sistema.
4. Ingrese el código de 6 dígitos que genera la app para confirmar el enrolamiento.



Figure 4: Pantalla de verificación del segundo factor (TOTP) con campo de 6 dígitos.

Una vez completado, su dispositivo quedará vinculado a su cuenta y el sistema le solicitará el código en cada inicio de sesión.

Activación de cuenta nueva

Si el administrador le registró como nuevo colaborador, recibirá un correo con un enlace de activación con vigencia de 48 horas. Siga estos pasos:

1. Haga clic en el enlace de activación del correo.
2. El sistema le pedirá que establezca una contraseña segura para su cuenta.
3. Defina una contraseña con mínimo 8 caracteres, combinando mayúsculas, minúsculas y números.
4. Complete el enrolamiento TOTP (ver sección 4.3).
5. Su cuenta quedará activada y podrá iniciar sesión normalmente.

Nota: Si el enlace expiró (más de 48 horas), contacte al administrador para que genere un nuevo registro.

Guía de Uso

Panel de administración (Dashboard)

Una vez autenticado, el sistema muestra el Dashboard principal con acceso a los módulos según su rol. Los administradores (Nivel 1) ven todos los módulos disponibles; los demás roles ven únicamente las secciones a las que tienen acceso.

El Dashboard presenta, según el nivel del usuario:

- **Niveles 1–3:** estadísticas de registros, bandeja de trabajo activa y accesos rápidos a los módulos.
- **Nivel 4:** acceso directo al formulario de registro de migrante.

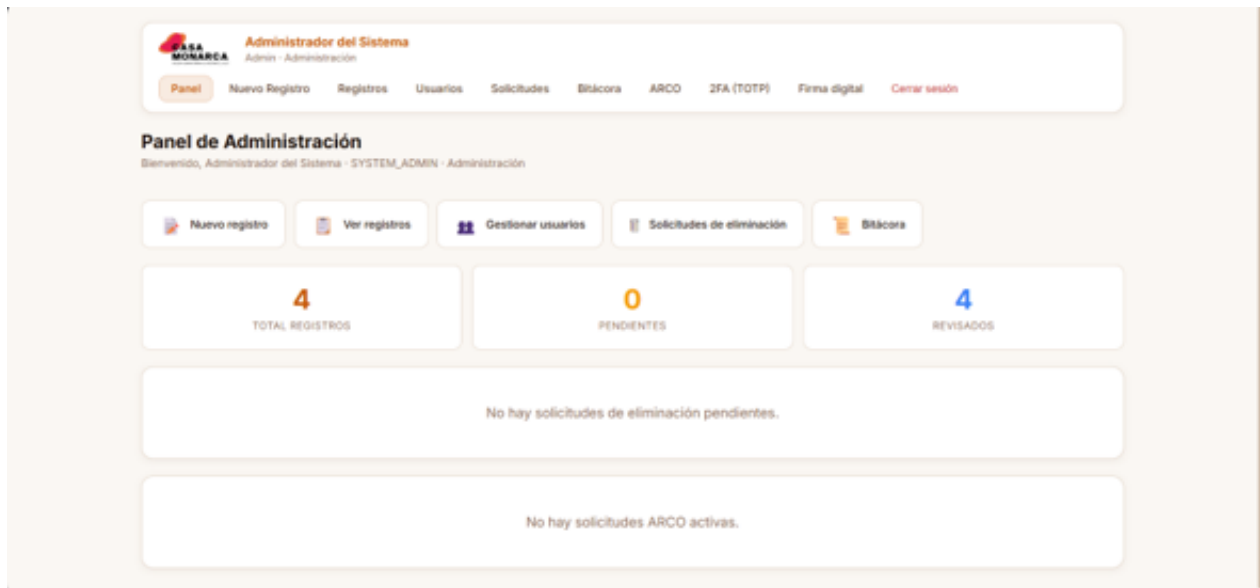


Figure 5: Dashboard principal con estadísticas de registros y bandeja de trabajo. Vista del Administrador (Nivel 1).

Registrar un nuevo colaborador

Disponible solo para Administradores del Sistema (Nivel 1).

Paso a paso:

1. En el menú lateral, navegue a **Usuarios**.
2. Haga clic en **Nuevo Usuario**.
3. Complete el formulario con los siguientes datos:
 - Nombre completo del colaborador.
 - Correo electrónico institucional (debe ser único en el sistema).
 - Área a la que pertenece.
 - Nivel de acceso (1–4) y rol correspondiente.
 - Fecha de inicio y fecha de expiración de la vigencia.
4. Haga clic en **Registrar**. El sistema validará que el correo no esté duplicado.
5. Al registrar correctamente, el sistema:
 - Crea el usuario con estado **PENDIENTE**.
 - Genera automáticamente un certificado de identidad RSA-2048.
 - Genera un token de activación con vigencia de 48 horas.
 - Envía el enlace de activación por correo (o lo almacena en modo demo).

Figure 6: Formulario de creación de nuevo colaborador con campos de nombre, correo, área, nivel y fechas de vigencia.

Resultado esperado:

El colaborador aparece en la lista con estado **PENDIENTE**. Una vez que active su cuenta, el estado cambia a **ACTIVO**.

Registrar una persona migrante

Disponible para todos los niveles (1, 2, 3 y 4).

Paso a paso:

1. Navegue a **Nuevo Registro** en el menú lateral.
2. Complete el formulario de ingreso:
 - **Nombre o alias** (se almacena cifrado para proteger la identidad).
 - **Fecha de atención.**
 - **Nacionalidad, idioma, rango de edad y género.**
 - **Información de contacto.**
 - **Grupo poblacional** (migrante en tránsito, solicitante de asilo, etc.).
 - **Observaciones adicionales y necesidades detectadas.**
3. Acepte el **Aviso de Privacidad** y los **Términos y Condiciones** (ambos obligatorios conforme a la LFPDPPP).
4. Haga clic en **Guardar Registro**.

Administrador del Sistema
Admin - Administración

Panel **Nuevo Registro** Registros Usuarios Solicitudes Bitácora ARCO 2FA (TOTP) Firma digital Cerrar sesión

Entrevista de ingreso al albergue

Casa Monarca · Ayuda Humanitaria al Migrante, A.B.P.

DATOS PERSONALES

Nombre de pila (sin apellidos) * Primer apellido * Segundo apellido Si no tiene, poner X

Número telefónico de contacto Género

ORIGEN

País de origen Departamento / Estado

DATOS DEMOGRÁFICOS

Estado civil Fecha de nacimiento

Figure 7: Formulario de ingreso de persona migrante con campos de datos básicos, grupo poblacional y casillas de aviso de privacidad.

Resultado esperado:

El sistema asigna automáticamente un folio único con formato CM-AAAA-NNNN (ejemplo: CM-2026-0001) y calcula el hash SHA-256 del registro para garantizar su integridad. El registro queda en estado **Pendiente** hasta ser revisado.

Consultar y gestionar registros de migrantes

Disponible para niveles 1, 2 y 3.

Buscar un registro:

1. Navegue a **Registros** en el menú lateral.
2. Utilice el buscador para filtrar por folio, nombre, nacionalidad o estado del workflow.
3. Haga clic sobre el folio o el botón **Ver** para acceder al expediente completo.

Administrador del Sistema
Admin - Administración

Panel Nuevo Registro **Registros** Usuarios Solicitudes Bitácora ARCO 2FA (TOTP) Firma digital Cerrar sesión

Registros de beneficiarios

5 registros encontrados [+ Nuevo registro](#)

Buscar Estado workflow

FOLIO	NOMBRE	PAIS	GÉNERO	WORKFLOW	FECHA	ACCIONES
CM-2026-0001	Ana Ponce	Brasil	Femenino	REVISADO	5/6/2026	Ver Eliminar
CM-2026-0004	[CANCELACIÓN ARCO]	---	LOBIQ+	REVISADO	4/6/2026	Ver Eliminar
CM-2026-0003	Hugo Jaime	---	Masculino	REVISADO	4/6/2026	Ver Eliminar
CM-2026-0002	[CANCELACIÓN ARCO]	---	Femenino	REVISADO	4/6/2026	Ver Eliminar
CM-2026-0001	Hugo Jaime	Venezuela	Masculino	REVISADO	4/6/2026	Ver Eliminar

Figure 8: Lista de registros de migrantes con columnas de folio, nombre, estado del workflow y fecha de atención.

Workflow de un registro:

Cada registro sigue un ciclo de vida con los siguientes estados:

Estado	Quién lo asigna	Significado
Pendiente	Sistema (automático)	Registro recién creado, en espera de revisión.
Revisado	Niveles 1, 2 o 3	El registro fue revisado y validado.
Canalizado	Nivel 3	El operativo lo derivó a un coordinador con comentario obligatorio.
Cerrado	Niveles 1 o 2	Gestión concluida. No se admiten más modificaciones.

Tabla 8. Estados del workflow de registros de migrantes y quién puede asignarlos.

Figure 9: Vista de detalle de un registro de migrante mostrando folio, estado del workflow, hash de integridad y botones de acción disponibles según el rol.

Aprobar un registro (Coordinador / Administrador):

1. Abra el registro en estado **Pendiente**.
2. Haga clic en **Aprobar / Revisar**.
3. El sistema solicitará su **archivo .key** y la **contraseña** de su certificado de firma.
4. Cargue el archivo .key y escriba su contraseña, luego confirme.
5. El registro pasa al estado **Revisado** y se guarda la firma digital como evidencia.

Módulo ARCO — Derechos de privacidad

Crear solicitudes: niveles 2 y 3. Atender: niveles 1 y 2.

El módulo ARCO implementa los derechos de **Acceso, Rectificación, Cancelación y Oposición** conforme a la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP).

Tipos de solicitud:

Tipo	Descripción	Flujo
ACCESS	El titular solicita conocer sus datos registrados.	Coordinador o admin atiende con firma.
RECTIFICATION	El titular solicita corregir datos incorrectos.	Coordinador o admin atiende con firma.
OPPOSITION	El titular se opone al tratamiento de sus datos.	Coordinador o admin atiende con firma.
CANCELLATION	El titular solicita la eliminación de sus datos (anonimización).	Coordinador escala; admin aprueba con firma.

Tabla 9. Tipos de solicitudes ARCO y sus flujos de atención.**Crear una solicitud ARCO:**

1. Navegue a **Solicitudes ARCO** en el menú lateral.
2. Haga clic en **Nueva Solicitud**.
3. Seleccione el **registro del beneficiario** afectado mediante su folio.
4. Elija el **tipo de solicitud** (ACCESS / RECTIFICATION / OPPOSITION / CANCELLATION).
5. Ingrese la **razón** y una **descripción** detallada de la solicitud.
6. Haga clic en **Registrar**. Se asigna automáticamente un folio ARCO-YYYY-NNNN.

Figure 10: Formulario de creación de solicitud ARCO con selector de tipo, campo de razón y descripción.

Atender una solicitud ARCO:

1. En la lista de solicitudes, identifique las asignadas a usted con estado **En Revisión**.
2. Abra la solicitud y revise los datos del beneficiario.
3. Complete el campo **Notas de resolución** con la acción tomada.
4. Cargue su **archivo .key** y escriba su **contraseña** de firma para confirmar la resolución.
5. Para solicitudes de tipo CANCELACIÓN (solo coordinador): use el botón **Escalar** al administrador.

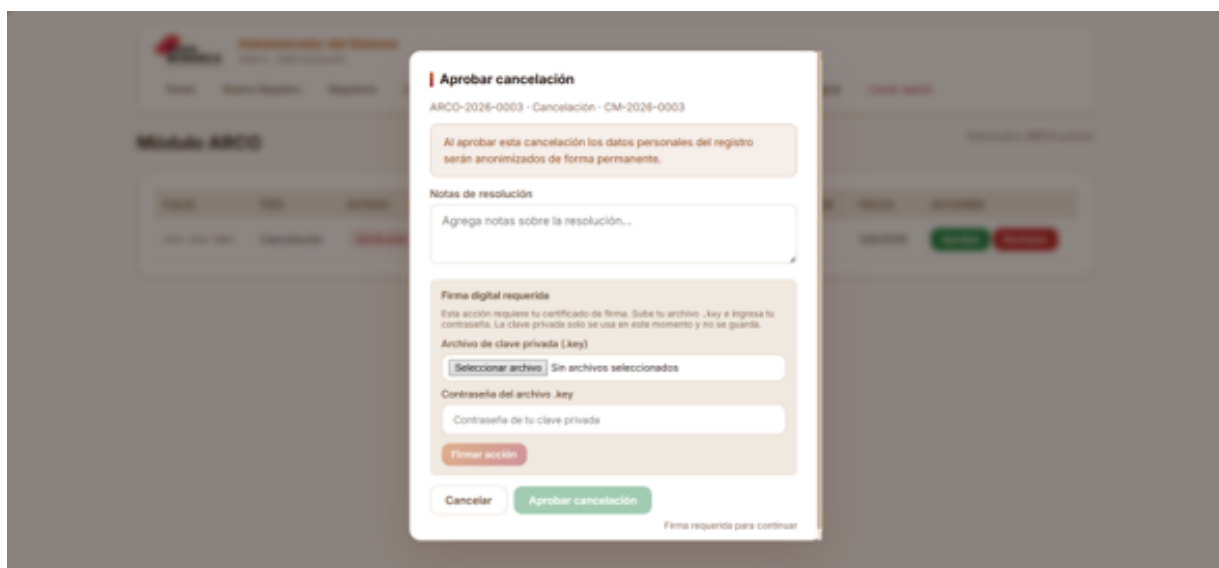


Figure 11: Vista de detalle de solicitud ARCO con estado En Revisión, notas de resolución y panel de firma digital.

Resultado de CANCELACIÓN aprobada: los campos de nombre y contacto del beneficiario se reemplazan por ANONIMIZADO de forma irreversible; el expediente permanece en el sistema pero sin datos de identidad.

Solicitudes de eliminación

Crear: niveles 1 y 2. Aprobar o rechazar: solo nivel 1.

Cuando un registro completo debe eliminarse de la base de datos, el flujo requiere autorización del administrador.

Solicitar la eliminación de un registro:

1. Abra el registro que desea eliminar.
2. Haga clic en **Solicitar eliminación**.
3. Ingrese la **razón** de la petición (obligatoria).
4. La solicitud queda en estado **Pendiente** con folio DEL-YYYY-NNNN y espera aprobación.

Figure 12: Formulario de solicitud de eliminación con campo de razón y folio del registro afectado.

Aprobar o rechazar (Administrador):

1. Navegue a **Solicitudes de Eliminación** en el menú lateral.
2. Abra la solicitud pendiente y revise la razón indicada.
3. Haga clic en **Aprobar** o **Rechazar**, según corresponda.
4. Ambas acciones requieren **firma digital** con archivo .key y contraseña.
5. Si se aprueba, el registro se elimina físicamente de la base de datos de forma inmediata e irreversible.

Figure 13: Lista de solicitudes de eliminación con columnas de folio, registro afectado, solicitante y estado.

Firma digital — Configuración del certificado

Disponible para niveles 1 y 2 únicamente.

Para poder aprobar registros, resolver solicitudes ARCO y autorizar eliminaciones, los usuarios de nivel 1 y 2 deben generar su certificado de firma ECDSA P-256.

Generar el certificado:

1. Navegue a **Configuración de Firma** en su perfil o menú de usuario.
2. Haga clic en **Generar certificado de firma**.
3. Establezca una **contraseña** para proteger su clave privada. Elija una contraseña segura que recuerde, ya que será solicitada en cada firma.
4. Descargue los dos archivos generados:
 - **.cer** — certificado público (puede compartirse para verificación).
 - **.key** — clave privada cifrada (**guárdela en un lugar seguro; no la comparta con nadie**).

Importante: el servidor **nunca** almacena su clave privada. La descarga es única; si pierde su archivo .key, deberá generar un nuevo certificado y el anterior quedará revocado.

Verificar una firma existente:

1. Abra el registro, solicitud ARCO o solicitud de eliminación que desea verificar.
2. En el panel de firma, haga clic en **Verificar firma**.
3. Opcionalmente, cargue el archivo **.cer** del firmante para una verificación cruzada.
4. El sistema mostrará si la firma es válida, quién firmó y en qué fecha.

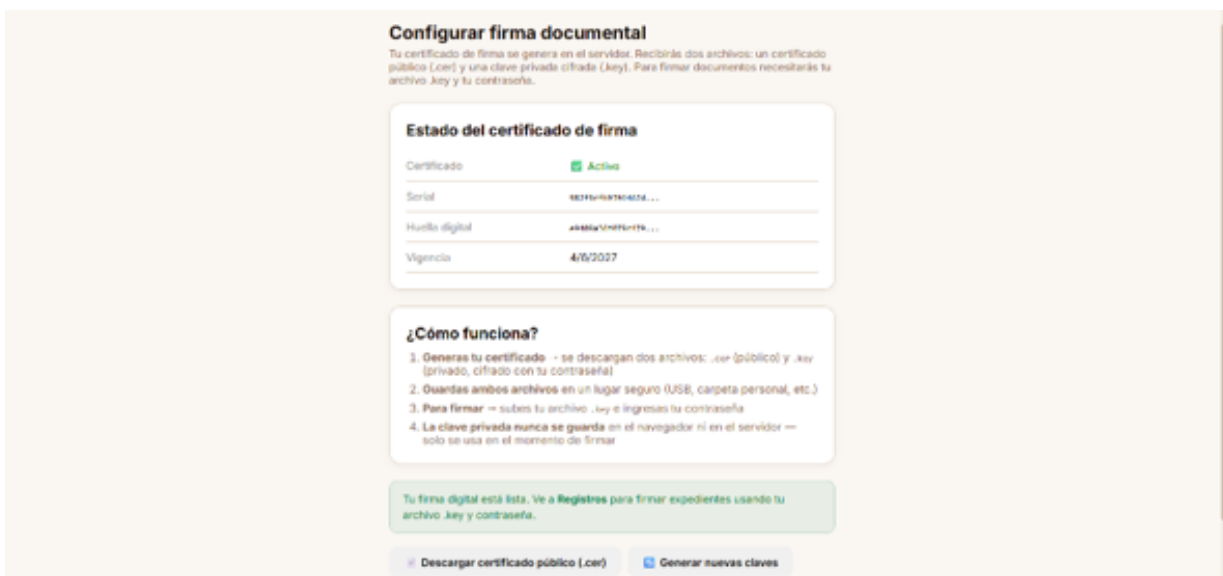


Figure 14: Panel de verificación de firma digital mostrando estado válido, nombre del firmante, fecha y resultado de la verificación con .cer.

Consultar la bitácora de auditoría

Disponible exclusivamente para Administradores del Sistema (Nivel 1).

Paso a paso:

1. Navegue a **Auditoría** → **Bitácora** en el menú lateral.
2. Utilice los filtros disponibles para acotar la búsqueda:
 - **Matrícula** del usuario actor (formato CM-USR-NNNN).
 - **Límite** de registros a mostrar.
3. Cada entrada muestra: folio del evento (BIT-NNNNN), fecha y hora, usuario actor con su matrícula, acción ejecutada, recurso afectado, resultado (**ÉXITO** / **ERROR**), IP de origen y hash relacionado.

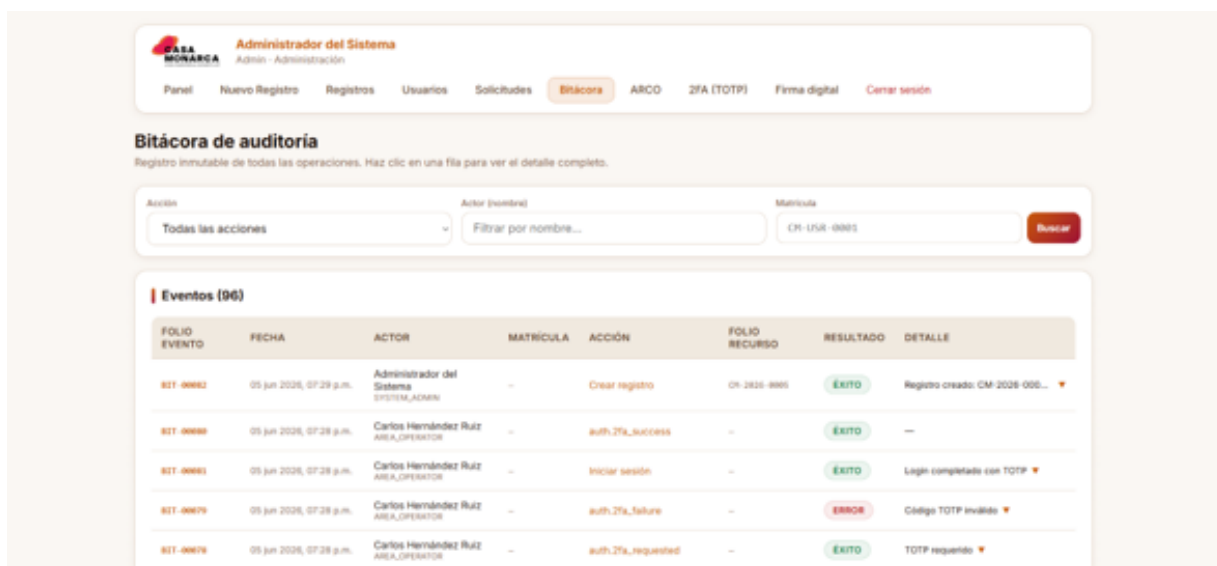


Figure 15: Bitácora de auditoría con tabla de eventos filtrados por matrícula, mostrando folio, fecha, actor, acción y resultado.

Nota: La bitácora es de solo lectura e **inmutable**. Ningún usuario, incluyendo el administrador, puede modificar o eliminar registros de auditoría desde la interfaz del sistema.

Gestionar el estado de un colaborador

Disponible exclusivamente para Administradores del Sistema (Nivel 1).

Desde el detalle de un colaborador (**Usuarios** → **seleccionar usuario**), el administrador puede ejecutar las siguientes acciones:

Acción	Cuándo usarla	Efecto en el sistema
Desactivar	El colaborador está de vacaciones o baja temporal.	Estado → INACTIVO. No puede iniciar sesión. Certificado suspendido.
Revocar	Incidente de seguridad, pérdida de credenciales o acceso no autorizado.	Estado → REVOCADO. Certificado invalidado permanentemente. Requiere nuevo registro.
Renovar vigencia	El periodo de vigencia está por expirar y el colaborador sigue activo.	Se actualiza la fecha de expiración y se reactiva el certificado.
Reactivar	Restablecer el acceso de un usuario desactivado temporalmente.	Estado → ACTIVO. Certificado reactivado.

Tabla 10. Acciones de gestión de estado disponibles para colaboradores y sus efectos en el sistema.

Solución de Problemas

Errores comunes y soluciones

Error / Síntoma	Causa probable	Solución
401 — Credenciales inválidas	Contraseña incorrecta o usuario inactivo/revocado.	Verificar correo y contraseña. Si el usuario está inactivo, contactar al administrador.
401 — Código TOTP incorrecto	Código expirado (>30 s) o reloj del dispositivo desincronizado.	Esperar al siguiente código. Si persiste, sincronizar la hora del teléfono en Configuración → Automática.
400 — Enlace de activación expirado	Token expirado (>48 h) o ya fue utilizado.	Contactar al administrador para revocar el usuario y crear uno nuevo.
403 — Acceso denegado	El nivel de acceso del usuario no tiene permiso para esa operación.	Verificar con el administrador el nivel de acceso asignado.
400 — Firma rechazada	Archivo .key incorrecto, contraseña errónea o certificado revocado.	Verificar que el archivo .key corresponde a su usuario y que la contraseña es correcta. Si el certificado fue revocado, generar uno nuevo.
500 — Error al generar certificado de firma	FIELD_ENCRYPTION_KEY no configurado en el servidor.	El administrador técnico debe definir FIELD_ENCRYPTION_KEY en el .env del backend.
Sistema no envía correos de activación	SMTP no configurado (modo demo activo).	Consultar enlaces desde GET /api/v1/auth/demo/pending-activations. Para correo real, configurar variables SMTP_* en .env.
Frontend no conecta con el backend	VITE_API_URL apunta a una URL incorrecta.	Verificar frontend/.env y reiniciar el servidor con npm run dev.
"El contenido firmado no corresponde a esta operación"	Intento de reutilizar una firma de otra operación (replay).	No reutilice firmas entre operaciones. Genere una nueva firma para cada acción.
"El registro ya fue anonimizado"	Se intenta operar sobre un expediente cuya CANCELLATION ya fue aprobada.	El registro no puede modificarse; la anonimización es irreversible.

Tabla 11. Errores comunes del sistema, causas probables y acciones de solución.

¿Qué hacer si algo falla inesperadamente?

1. Tome nota del **mensaje de error exacto** que muestra la pantalla.
2. Anote la **acción que realizaba** cuando ocurrió el error.
3. Cierre sesión y vuelva a iniciarla para descartar problemas de sesión expirada.
4. Si el problema persiste, contacte al administrador técnico con la información del error.

Preguntas Frecuentes (FAQ)

¿Por qué el sistema pide un código de teléfono cada vez que inicio sesión?

El sistema implementa autenticación de doble factor (2FA) obligatoria para proteger las cuentas, especialmente porque se maneja información sensible de personas en situación vulnerable. Este segundo factor impide que alguien que conozca su contraseña pueda acceder sin tener también su teléfono.

¿Qué pasa si pierdo mi teléfono con la aplicación autenticadora?

Contacte inmediatamente al administrador del sistema. El administrador puede revocar su secreto TOTP desde el panel de gestión de identidades, lo que le permitirá enrollar un nuevo dispositivo la próxima vez que intente iniciar sesión.

¿El sistema guarda las claves privadas de los documentos que firmo?

No. Las claves privadas ECDSA P-256 se generan y permanecen en su navegador mediante la Web Crypto API. El servidor nunca recibe ni almacena su clave privada. Solo se almacena el certificado público (.cer) y la firma resultante.

¿Cómo sé si un registro de migrante ha sido alterado?

Cada registro contiene un hash SHA-256 calculado al momento de su creación. La bitácora registra todos los cambios realizados, junto con la identidad del actor y la hora exacta. Un administrador puede verificar la integridad comparando el hash almacenado con el calculado sobre los datos actuales.

¿Puedo usar el sistema desde mi teléfono celular?

Sí. El sistema es una aplicación web accesible desde cualquier navegador moderno. Sin embargo, para operaciones de firma digital se recomienda el uso de una computadora de escritorio o laptop, ya que el flujo de carga de archivos .key y .cer puede resultar incómodo en pantallas pequeñas.

¿Qué significa el estado REVOCADO en un usuario?

Un usuario revocado tiene su identidad digital permanentemente invalidada. A diferencia de un usuario desactivado (que puede reactivarse), la revocación es definitiva: el certificado queda marcado como revocado y el usuario no puede iniciar sesión. Si el colaborador regresa a la organización, deberá crearse un registro completamente nuevo.

¿Mis datos personales están protegidos en el sistema?

Sí. Los campos sensibles (nombre o alias, información de contacto) se almacenan cifrados mediante Fernet (AES-128-CBC + HMAC-SHA256). Las contraseñas se guardan como hash bcrypt y el secreto TOTP se almacena cifrado. La comunicación debe realizarse siempre por HTTPS en producción.

¿Qué diferencia hay entre una solicitud ARCO de tipo CANCELación y una solicitud de eliminación?

La **CANCELACIÓN** (ARCO) es el derecho del propio beneficiario a que sus datos sean anonimizados: sus campos de identidad se sustituyen por ANONIMIZADO pero el expediente permanece en el sistema. La **solicitud de eliminación** es una petición interna del personal para borrar físicamente el registro completo de la base de datos, y requiere autorización del administrador.

¿Qué ocurre cuando una cuenta de colaborador expira?

Al intentar iniciar sesión con una cuenta cuya fecha de expiración ha sido superada, el sistema rechaza automáticamente el acceso con el mensaje "La cuenta ha expirado". El administrador puede renovar la vigencia desde el detalle del usuario.

¿Puedo ver quién firmó una resolución ARCO o de eliminación?

Sí. En el detalle de cualquier solicitud resuelta, el panel de firma muestra el nombre del firmante, su matrícula, la fecha y hora de la firma, y el algoritmo utilizado. Además, cualquier usuario de nivel 1 a 3 puede verificar la firma con el archivo .cer del firmante.

Glosario

Término	Definición
2FA / Doble factor	Mecanismo de autenticación que combina algo que el usuario sabe (contraseña) y algo que tiene (teléfono con app autenticadora) para verificar su identidad.
ARCO	Derechos de Acceso, Rectificación, Cancelación y Oposición reconocidos por la LFPDPPP. Permiten a los titulares de datos personales ejercer control sobre su información.
Bitácora de auditoría	Registro inmutable y cronológico de todas las acciones críticas realizadas en el sistema. Cada entrada tiene un folio único (BIT-NNNNN) y no puede modificarse ni eliminarse.
Certificado (.cer)	Archivo que contiene la clave pública de un usuario y su información de identidad, firmado por el sistema. Puede compartirse para verificar firmas digitales.
ECDSA P-256	Algoritmo de firma digital de curva elíptica con curva P-256. Equivalente funcional al mecanismo de firma del SAT mexicano.
Fernet	Esquema de cifrado simétrico autenticado que combina AES-128-CBC y HMAC-SHA256. Utilizado para cifrar campos sensibles en la base de datos.
Folio	Identificador único asignado automáticamente a cada entidad del sistema. Ejemplos: CM-2026-0001 (registro), ARCO-2026-0003 (solicitud ARCO), BIT-00204 (evento de bitácora).
Hash SHA-256	Valor de 256 bits calculado a partir del contenido de un registro. Si cualquier campo es alterado, el hash cambia, permitiendo detectar modificaciones no autorizadas.
JWT	JSON Web Token. Credencial digital firmada que el sistema entrega al usuario tras la autenticación. Contiene la identidad y los permisos del usuario y tiene vigencia limitada.
.key (archivo)	Archivo que contiene la clave privada ECDSA del usuario, protegida con cifrado AES-256-GCM. Es exclusivo del usuario; el servidor no lo almacena.
LFPDPPP	Ley Federal de Protección de Datos Personales en Posesión de los Particulares. Marco legal mexicano que regula el tratamiento de datos personales y reconoce los derechos ARCO.
Matrícula	Identificador único asignado a cada colaborador registrado en el sistema. Formato: CM-USR-NNNN (ejemplo: CM-USR-0003).
RBAC	Control de Acceso Basado en Roles. Modelo que define los permisos de cada usuario según el rol y nivel que le asignó el administrador.

TOTP	Contraseña de un solo uso basada en el tiempo (Time-based One-Time Password, RFC 6238). Código de 6 dígitos que cambia cada 30 segundos, generado por la app autenticadora.
Workflow	Flujo de estados por el que pasa un registro de migrante: Pendiente → Revisado / Canalizado → Cerrado.

Tabla 12. Glosario de términos técnicos y del dominio utilizados en el sistema.

Repositorio del proyecto

https://github.com/mirandacornejoa/Reto_CasaMonarca_Eq1_603